

MIS-9 / Безопасность (Security & ALE)

Данные зашифрованы в БД

Priority	Severity	Behavior	Type
Not set	Blocker	Positive	Security
Layer	Is Flaky	Is Muted	Automation
API	No	No	To be automated
Status	Milestone		
Actual	-		

Preconditions

Есть доступ к базе данных PostgreSQL (через DBeaver, pgAdmin или консоль `psql`).

Steps to reproduce

#	Step	Action	Expected Result
1	Авторизоваться в приложении и создать пациента с уникальным ФИО.	ФИО: <code>Петров Пётр Петрович</code> Первичный диагноз: <code>Здоров</code>	Пациент успешно создан и отображается в браузере (данные расшифровываются "на лету" мастер-паролем из ОЗУ).
2	Подключиться к БД напрямую в обход бэкенда и выполнить SQL-запрос для просмотра записей.	<code>SELECT "fullName", "admissionDiagnosis" FROM "Patient" ORDER BY "createdAt" DESC LIMIT 1;</code>	Запрос выполнен успешно.
3	Проверить содержимое колонок <code>fullName</code> и <code>admissionDiagnosis</code> у последней записи.		Данные полностью нечитаемы

MIS-10 / Безопасность (Security & ALE)

Разграничение прав (Role-Based Access Control - RBAC)

Priority	Severity	Behavior	Type
Not set	Critical	Negative	Functional
Layer	Is Flaky	Is Muted	Automation
API	No	No	To be automated
Status	Milestone		
Actual	-		

Preconditions

Существует учетная запись с ролью `Doctor` (Врач) и ролью `Admin` (Администратор).

Steps to reproduce

#	Step	Action	Expected Result
1	Авторизоваться под учетной записью с ролью Врач .	Логин: testdoctor Пароль: testpassword	Авторизация успешна.
2	Проверить навигационное меню на наличие админских разделов.		Кнопки "Заблокировать систему", "Мониторинг (Grafana)", "Настройки системы" скрыты из интерфейса для этой роли.
3	Попытаться принудительно перейти по URL-адресу панели администратора.	URL: http://localhost/admin	Приложение блокирует доступ. Происходит редирект на главную страницу.

MIS-11 / Безопасность (Security & ALE)

Уязвимость IDOR (Подмена токена для доступа к API)

Priority	Severity	Behavior	Type
Not set	Critical	Destructive	Security
Layer	Is Flaky	Is Muted	Automation
API	No	No	To be automated
Status	Milestone		
Actual	-		

Preconditions

Установлен инструмент Postman. Пользователь авторизован как **Врач**.

Steps to reproduce

#	Step	Action	Expected Result
1	Открыть консоль разработчика в браузере (F12) → Application → LocalStorage (или Cookies) и скопировать свой токен авторизации.		Токен скопирован.
2	Открыть Postman и сформировать прямой HTTP-запрос к эндпоинту, предназначенному только для администраторов .	Метод: POST URL: http://localhost/api/system/lock Headers: Authorization: Bearer <токен_врача>	Запрос сформирован.
3	Отправить запрос.		Бэкенд перехватывает запрос, расшифровывает токен, видит роль Doctor и отклоняет выполнение операции . Сервер возвращает статус-код 403 Forbidden (или 401 Unauthorized).

Блокировка крипто-модуля (Сброс Мастер-пароля из ОЗУ)

Priority	Severity	Behavior	Type
Not set	Major	Positive	Security
Layer	Is Flaky	Is Muted	Automation
API	No	No	To be automated
Status	Milestone		
Actual	-		

Preconditions

Система разблокирована (мастер-пароль введен, пациенты успешно расшифровываются). Авторизован Администратор.

Steps to reproduce

#	Step	Action	Expected Result
1	Будучи администратором, нажать кнопку "Заблокировать систему" или отправить POST-запрос на <code>/api/system/lock</code> .		Запрос выполняется успешно (Статус 200 OK). Мастер-пароль удаляется из оперативной памяти сервера.
2	Попытаться перейти на страницу списка пациентов.	URL: <code>http://localhost/persons</code>	Сервер больше не может расшифровать данные. Происходит редирект на страницу ввода мастер-пароля.